

Web Application Security Assessment

newsouthtechnologies.com

Penetration-test-style review — external attack surface, sensitive-data exposure, and the careers submission pipeline.

CONFIDENTIAL — RESTRICTED DISTRIBUTION. This document identifies exploitable weaknesses and the exact URLs of exposed assets. Do not publish it, commit it to the website repository, or share it beyond need-to-know.

Field	Detail
Prepared for	New South Technologies — Co-Managing Partners
Assessed by	Senior Penetration Tester
Date	July 26, 2026
Assessment type	Authorized, non-destructive grey-box review: unauthenticated live requests against the public site plus source-assisted inspection of the Cloudflare Pages deployment and the /api/forms/careers function.
Scope	newsouthtechnologies.com, its Pages Functions, and artifacts published from the site's repository.
Out of scope	Exploitation of third-party providers (Formspree, Cookiebot, Cloudflare, Azure); social engineering; denial-of-service testing.
Classification	Confidential — restricted

Disclaimer: a professional security assessment to guide remediation, not a warranty that the site is free of vulnerabilities. Findings are as of the review date; third-party and infrastructure behavior may change.

1. Executive Summary

The application code is in reasonable shape. No credentials, API keys, private keys, or connection strings are present in the deployed source; configuration is environment-based; the careers endpoint enforces consent, validates and sanitizes input, and has recently gained an origin-locked CORS policy and Cloudflare-KV rate limiting. The .git directory is not exposed, and TLS is handled by the platform.

The dominant risk is information exposure, not code execution. The public web root serves multiple files that should never have been published. The most sensitive is a personal family biography containing the private names of named individuals — unrelated to the business and evidently committed by accident. Alongside it sits a complete kit of internal branding and legal templates (letterhead, email signature, business card, NDA, MSA, SOW, engagement letter, invoice, proposal). For a federal contractor, that kit materially lowers the bar for convincing impersonation and spear-phishing against the firm, its job applicants (who submit resumes, clearance status, and PII), and the agencies it is courting.

Separately, the site's HTTP security-header policy is defined but not served in production because the configuration file is misnamed, leaving no CSP, HSTS, or clickjacking protection live today.

Top priorities: (1) remove the internal files from the deployed site and prevent recurrence; (2) never commit the compliance/security reports to the public repo; (3) ship the security headers; (4) finish hardening the careers upload pipeline.

Risk summary

Severity	Count	Representative findings
High	4	Personal-data exposure; impersonation/phishing template kit exposed; risk of publishing the vuln reports; security headers not

Severity	Count	Representative findings
		served (live).
Medium	2	Careers upload validation & PII-in-logs; third-party/supply-chain surface without SRI.
Low	2	Soft-404 returns 200; config files disclose infra intent.
Positive	—	No hardcoded secrets; .git not exposed; consent/validation/rate-limiting on the careers endpoint; TLS + email obfuscation.

2. Assets Exposed to the Public That Should Be Restricted

Everything committed to the site repository is deployed by Cloudflare Pages and reachable without authentication. The following were confirmed present in the deployed source (personal-data file confirmed live):

URL	What it discloses	Risk
/Documents.txt	Personal family biography; full private names of named individuals; unrelated to the business	High
/documents/Templates/letterhead.html, email-signature.html, business-card.html	Brand assets that enable forged, on-brand documents and emails	High
/documents/Templates/nda-mutual.html, msa-..., sow-template.html, engagement-letter.html, invoice-template.html, proposal-template.html, capability-statement.html	Internal legal & commercial templates	Medium
/research_notes.md	Internal market-positioning strategy and keyword research	Medium
/QA-Peer-Review-Report.html	Internal QA review document	Medium
/CLAUDE.md	Internal build/AI-agent context	Low
/wangler.toml, /_headers.txt	Deployment intent (KV/env-var names, Azure) and the intended header policy	Low
(risk) /*.docx security & compliance reports	A complete map of the site's own weaknesses, if ever committed	High

Root cause: no separation between repository source and published output, and a .gitignore that did not exclude internal artifacts. (This assessment has already extended .gitignore to exclude these; the already-committed files still require removal — see remediation.)

3. Detailed Findings

F-1 Sensitive internal files served from the web root

Severity: **High**

Confirmed: /Documents.txt returns a personal family biography (private individuals' names) with HTTP 200 and text/plain — a privacy/PII exposure on a federal-contractor domain. The same web root also serves internal notes, an AI-context file, a QA report, and internal legal/branding templates. Impact: privacy harm, competitive intelligence, and reconnaissance. Remediation: remove these from the deployed output (git rm --cached + the now-updated .gitignore), or move the site's publishable assets into a dedicated output directory and point Cloudflare Pages at it; then re-scan the live site to confirm each URL now 404s.

F-2 Impersonation / phishing kit exposed

Severity: **High**

The exposed letterhead, email-signature, and business-card templates, combined with the publicly listed leadership names and titles and the internal contract templates, provide everything needed to forge on-brand NST correspondence. The highest-value target is the careers channel: an attacker can impersonate NST to solicit resumes, clearance details, and PII from applicants, or pose as NST to agencies and partners (business-email-compromise). Remediation: remove the templates from the public site; enforce email anti-spoofing (SPF, DKIM, and a DMARC policy at p=reject) so forged NST email is rejected; brief staff and applicants on the official application channel.

F-3 Risk of publishing the security/compliance reports

Severity: **High**

The compliance QA report — and this assessment — enumerate the site's exact weaknesses. The QA .docx currently sits, untracked, in the deploy root; a routine "git add -A" would publish it at a guessable URL. Remediation: keep all such reports out of the website repository (now covered by the *.docx .gitignore rule); distribute them only through a private channel; if any report was ever committed, purge it from history and rotate any details it revealed.

F-4 HTTP security headers not served (production)

Severity: **High**

The live site returns no Content-Security-Policy, Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, or Permissions-Policy, because the policy file is named "_headers.txt" while Cloudflare Pages only applies a file named exactly "_headers". Impact: clickjacking (no framing protection), no HSTS (protocol-downgrade / SSL-strip window on first visit), and MIME-sniffing exposure. A corrected "_headers" with a CSP is staged in the repository but is not yet deployed. Remediation: deploy it, delete the misnamed file, and verify with an external header scan (e.g., securityheaders.com).

F-5 Careers upload endpoint hardening

Severity: **Medium**

Source review of /api/forms/careers (handles resumes, clearance status, and PII):

- **File validation trusts client input** — the type check relies on the browser-supplied MIME type and file extension; there is no magic-byte inspection and no malware scan (a hook exists). Arbitrary content can be uploaded labelled as a PDF. Files are stored in Azure Blob (not executed or served back), so direct code execution is unlikely, but malicious files could reach a reviewer's endpoint. Add server-side content-type verification and AV scanning before storage.
- **Body is fully buffered before the size check** — request.formData() reads the whole request before the 5MB limit is evaluated, allowing memory pressure from oversized uploads. Reject on Content-Length early.
- **PII in logs** — applicant email, IP, and position are logged. Ensure log access and retention are controlled for PII/CUI.

- **Retention is a stub** — the 18-month/7-year deletion is logged, not enforced; implement it via an Azure Blob lifecycle policy.

Positive: consent is enforced, inputs are sanitized, submission IDs and an audit trail are generated, and origin-locked CORS plus Cloudflare-KV rate limiting are staged in the repository (pending secrets/KV binding).

Update (post-assessment): content-based magic-byte validation and an early Content-Length/size guard have been implemented in the handler and tested; server-side AV scanning and Azure-lifecycle retention enforcement remain outstanding.

F-6 Third-party and supply-chain surface

Severity: Medium

Lead forms POST to Formspree (PII egress to a third party); Cookiebot and Google Fonts load third-party script/style. External scripts carry no Subresource Integrity (SRI), so a compromise of a third-party origin could inject code into the site. Remediation: add SRI hashes where feasible; rely on the new CSP to constrain script/style/connect sources; review third-party data-processing agreements for the PII paths.

F-7 Soft-404 returns HTTP 200

Severity: Low

Unknown paths (e.g., /.git/config) return HTTP 200 with the homepage rather than a 404. This aids automated path-probing and harms SEO. Configure a proper 404 response.

F-8 Configuration files disclose infrastructure intent

Severity: Low

/wangler.toml and /_headers.txt reveal KV/binding and environment-variable names, the Azure storage design, and the intended header policy — low-value reconnaissance that is unnecessary to publish. Removed by the F-1 remediation.

4. Prioritized Remediation

ID	Finding	Severity	Action
F-1	Internal files served from web root (incl. personal PII)	High	git rm --cached Documents.txt research_notes.md CLAUDE.md QA-Peer-Review-Report.html; git rm -r --cached documents/ ; commit & redeploy; re-scan live to confirm 404s. .gitignore already updated.
F-2	Impersonation/phishing template kit exposed	High	Remove branding/legal templates from the public site; enforce SPF/DKIM/DMARC (p=reject); publish the official application channel.
F-3	Vulnerability/compliance reports could be published	High	Keep reports out of the web repo (now gitignored *.docx); distribute privately; purge from history if ever committed.
F-4	Security headers not served (misnamed file)	High	Deploy the corrected “_headers” (with CSP); delete “_headers.txt”; verify with a header scan.
F-5	Careers upload validation & PII handling	Medium	Partly done: magic-byte content check + early size guard added & tested. Remaining: server-side AV scan, restrict PII in logs, enforce Azure-lifecycle retention, bind KV/secrets.
F-6	Third-party scripts without SRI; PII egress	Medium	Add SRI; keep CSP tight; review third-party DPAs.
F-7	Soft-404 returns 200	Low	Configure a real 404 page/response.
F-8	Config files disclose infra intent	Low	Do not deploy wangler.toml/_headers.txt (covered by F-1).

5. What Is Already Solid

- **No secrets in source** — no API keys, private keys, passwords, or connection strings in the deployed code; configuration is environment-based.
- **.git not exposed** — the repository history is not downloadable from the site.
- **Careers endpoint discipline** — consent enforcement, input validation/sanitization, submission IDs, audit logging, and staged origin-locked CORS + KV rate limiting.
- **Transport & anti-spam** — TLS 1.3 via Cloudflare, email-address obfuscation, form honeypots, and managed AI-bot/robots controls.

Appendix A — Email Anti-Spoofing (SPF / DKIM / DMARC)

Because the exposed branding templates and public leadership names make forged NST email easy to craft (finding F-2), the decisive control is a correctly configured SPF + DKIM + DMARC trio on the newsouthtechnologies.com DNS. Publish the following (exact values depend on your mail provider). Stand these up before the domain is used for outreach.

1. SPF — authorize your senders

One TXT record at the domain root listing every legitimate sending service, ending in a hard fail (-all). Keep a single SPF record and stay within 10 DNS lookups.

- Google Workspace: **v=spf1 include:_spf.google.com -all**
- Microsoft 365: **v=spf1 include:spf.protection.outlook.com -all**
- Add includes for any other senders you actually use (e.g., a marketing platform, SendGrid for transactional mail): **include:sendgrid.net**, etc. Do not leave “+all” or “~all” once senders are confirmed.

2. DKIM — cryptographically sign your mail

Enable DKIM signing in your mail provider, then publish the provider-generated public-key TXT at the selector host it gives you (for example `google._domainkey.newsouthtechnologies.com`, or `selector1/selector2._domainkey` for Microsoft 365). Rotate keys periodically. DKIM is what lets receivers verify the message was not altered and truly originated from your domain.

3. DMARC — tell receivers to reject forgeries

Publish a TXT record at `_dmarc.newsouthtechnologies.com`. Start in monitor mode, review the aggregate (RUA) reports for two to four weeks to confirm all legitimate mail aligns, then tighten to reject.

- Phase 1 (monitor): **v=DMARC1; p=none; rua=mailto:dmarc@newsouthtechnologies.com; fo=1; adkim=s; aspf=s**
- Phase 2 (enforce): **v=DMARC1; p=quarantine; pct=50; rua=mailto:dmarc@newsouthtechnologies.com; adkim=s; aspf=s** → then **p=reject; pct=100**

Only `p=reject` actually causes receiving servers to drop mail that forges your domain. Strict alignment (`adkim=s; aspf=s`) prevents look-alike sub-domain tricks.

4. Reinforcing controls

- **BIMI** (your logo shown in supporting inboxes) — requires DMARC at quarantine/reject and, for most mailbox providers, a Verified Mark Certificate.
- **MTA-STS + TLS-RPT** — enforce TLS on inbound mail and receive failure reports.
- **security.txt** at `/.well-known/security.txt` — a published channel for researchers to report issues responsibly.
- **Operational**: publish the single official application URL (`newsouthtechnologies.com/careers`) and state plainly that NST never requests resumes or clearance details through any other address — the careers channel is the highest-value impersonation target.

6. Methodology & Responsible Handling

Testing was authorized and non-destructive: unauthenticated HTTP requests against the live site to confirm exposure, combined with source-assisted (grey-box) inspection of the Cloudflare Pages deployment and the careers Pages Function. No third-party providers were exploited and no denial-of-service testing was performed. Because this report contains exploitation-relevant detail and the precise URLs of exposed assets, it must be treated as confidential and restricted to need-to-know; it must not be committed to the website repository.

End of report.